

LABORATORIO DE CONTINUACIÓN — ACTIVE DIRECTORY

Operación, detección, investigación y respuesta en un entorno empresarial simulado

Esta fase continúa tu laboratorio anterior sin repetir la instalación de Windows Server, Active Directory, DNS, DHCP, servidor de archivos, usuarios, OU, permisos y GPO. Tu documento anterior ya establece esa infraestructura y propone pasar hacia detección, investigación y respuesta. ■filecite■turn0file0■L197-L224■

Importante: esta versión NO utiliza Kali Linux. Todo se realizará únicamente con Windows Server, el equipo cliente y las herramientas administrativas/auditoría que ya tienes.

El objetivo es que puedas presentar el laboratorio como una actividad de entorno real: aparece una situación, produces evidencia, investigas, tomas una decisión, corriges y vuelves a validar.

1. ESCENARIO

Empresa: Bladimir Corp. **Dominio:** bladimir.lab

El equipo de TI recibe un reporte de que un usuario no puede iniciar sesión. Al revisar el entorno se observan varios intentos de autenticación fallidos. Debes investigar el caso y determinar si existe un problema de contraseña, bloqueo de cuenta o actividad administrativa no esperada.

2. EQUIPOS NECESARIOS

Equipo	Función
DC01 / Windows Server	Active Directory, DNS, DHCP, GPO, Event Viewer y administración
CLIENT01 / Windows 10/11	Equipo cliente unido al dominio

No necesitas una tercera máquina. El laboratorio completo se puede realizar con estas dos VMs.

3. FASE 1 — PREPARACIÓN Y LÍNEA BASE

Crea una estructura para conservar la evidencia:

```
New-Item -ItemType Directory -Path C:\Laboratorio\IR -Force
New-Item -ItemType Directory -Path C:\Laboratorio\Reportes -Force
New-Item -ItemType Directory -Path C:\Laboratorio\Evidencia -Force
```

Genera una copia documental de las GPO existentes:

```
Import-Module GroupPolicy
Get-GPOReport -All -ReportType Html -Path "C:\Laboratorio\Reportes\GPO-Baseline.html"
```

Antes de comenzar registra fecha, hora, servidor, cliente, IP, usuario y estado inicial.

4. FASE 2 — CREAR CUENTA DE INVESTIGACIÓN

En Active Directory Users and Computers crea una cuenta exclusiva para el ejercicio:

```
Usuario: prueba.ir
OU: TI
Descripción: Cuenta de laboratorio para investigación de incidentes
```

No utilices cuentas administrativas reales. El propósito es generar actividad controlada que puedas investigar.

5. FASE 3 — SIMULAR AUTENTICACIONES FALLIDAS

Desde CLIENT01 intenta iniciar sesión con una contraseña incorrecta varias veces, de acuerdo con la política de bloqueo que configuraste anteriormente.

Cuando la cuenta se bloquee, vuelve a DC01 y abre **Event Viewer** → **Windows Logs** → **Security**. Busca los eventos relacionados con los intentos fallidos y el bloqueo.

Para cada evento registra: ID, fecha/hora, usuario, equipo de origen, tipo de actividad y resultado.

Dato	Ejemplo
Cuenta	prueba.ir
Origen	CLIENT01
Actividad	Autenticación fallida
Resultado	Cuenta bloqueada
Evidencia	Evento Security + .evtx

6. FASE 4 — INVESTIGACIÓN

Ahora trabaja como analista. No te limites a decir que la cuenta fue bloqueada.

Debes responder: ¿qué cuenta fue afectada?, ¿cuándo comenzaron los fallos?, ¿desde qué equipo?, ¿cuántos eventos observaste?, ¿qué política provocó el bloqueo?, ¿la actividad fue esperada?, ¿qué evidencia respalda la conclusión?

Construye una línea de tiempo con los eventos encontrados.

7. FASE 5 — RESPUESTA Y RECUPERACIÓN

Simula el procedimiento de atención del incidente.

- 1. Identificación:** confirmar la cuenta y evidencia.
- 2. Contención:** deshabilitar temporalmente la cuenta si corresponde.
- 3. Corrección:** restablecer la contraseña y resolver la causa simulada.
- 4. Recuperación:** habilitar la cuenta cuando sea seguro.
- 5. Validación:** realizar un inicio de sesión legítimo.

```
Disable-ADAccount -Identity "prueba.ir"  
Set-ADAccountPassword -Identity "prueba.ir" -Reset -NewPassword (Read-Host -AsSecureString "Nueva contraseña")  
Enable-ADAccount -Identity "prueba.ir"
```

Estos comandos deben utilizarse solamente con la cuenta creada para el laboratorio.

8. FASE 6 — INVESTIGAR CAMBIOS ADMINISTRATIVOS

Realiza una segunda situación controlada: modifica la contraseña o un atributo no crítico de **prueba.ir**. Luego investiga quién realizó la modificación.

Busca el evento correspondiente en Security y documenta: **actor** → **acción** → **cuenta objetivo** → **fecha/hora** → **equipo** → **evidencia** → **conclusión**.

El resultado debe permitir demostrar que puedes diferenciar una acción administrativa legítima de una acción que requeriría investigación.

9. FASE 7 — MÍNIMO PRIVILEGIO

Crea un usuario llamado **auditor.lab**. Asígnale únicamente los permisos necesarios para consultar una carpeta de auditoría.

Prueba dos escenarios: acceso permitido al recurso que necesita y acceso denegado a una carpeta privada, por ejemplo RRHH.

Documenta el grupo utilizado, permisos NTFS, permisos de recurso compartido, resultado observado y corrección si existe una diferencia.

10. FASE 8 — VALIDAR GPO

Selecciona una de tus GPO anteriores, como Firewall, Windows Update, restricciones o bloqueo de acceso.

```
gpupdate /force
gpresult /h C:\Laboratorio\Reportes\CLIENT01-GPResult.html
Start-Process "C:\Laboratorio\Reportes\CLIENT01-GPResult.html"
```

Compara lo configurado en la GPO con lo que realmente recibe CLIENT01. Documenta **configuración esperada** → **configuración aplicada** → **prueba** → **resultado**.

11. FASE 9 — AUDITORÍA Y CORRELACIÓN

Tu laboratorio anterior ya documenta actividades como inicios de sesión, usuarios creados/eliminados, cambios de contraseña, usuarios modificados y equipos modificados. ■filecite■turn0file0■L169-L195■

En esta nueva fase debes correlacionar esa información con los eventos de Windows. Ejemplo: **reporte de auditoría** → **usuario modificado** → **Security** → **administrador responsable** → **conclusión**.

12. FASE 10 — CONSERVACIÓN DE EVIDENCIA

Organiza el caso INC-001 de esta manera:

```
C:\Laboratorio\Evidencia\INC-001\
01-línea-tiempo.txt
02-eventos-security.evtx
03-gpo-baseline.html
04-capturas\
05-analisis.txt
06-correccion.txt
07-validacion.txt
```

Desde Event Viewer usa **Save Selected Events** para conservar los eventos seleccionados en formato .evtx. Las capturas deben complementar la evidencia.

13. EJEMPLO DE LÍNEA DE TIEMPO

Hora	Evento	Actor	Origen	Resultado
10:02	Login fallido	prueba.ir	CLIENT01	Fallido
10:03	Login fallido	prueba.ir	CLIENT01	Fallido
10:04	Bloqueo	prueba.ir	CLIENT01	Bloqueada
10:07	Investigación	Administrador	DC01	Analizado
10:10	Contención	Administrador	DC01	Deshabilitada
10:15	Recuperación	Administrador	DC01	Restaurada

Los datos anteriores son solamente un ejemplo. En tu informe utiliza las horas y eventos reales de tu laboratorio.

14. RETO INC-002 — PERMISOS DE ARCHIVOS

Simula que un empleado legítimo pierde acceso a un recurso compartido después de una modificación de permisos.

Debes identificar qué permiso cambió, qué usuario o grupo está involucrado, comprobar si el cambio fue autorizado, corregirlo y demostrar nuevamente el acceso.

Este reto conecta Active Directory, grupos, permisos NTFS, servidor de archivos y auditoría.

15. ENTREGABLE FINAL

- ☐ Diagrama de la infraestructura.
- ☐ Inventario de DC01 y CLIENT01.
- ☐ Línea base de GPO.
- ☐ Cuenta de prueba.
- ☐ Evidencias de autenticación fallida.
- ☐ Evidencia de bloqueo.
- ☐ Investigación de modificación de usuario.
- ☐ Prueba de mínimo privilegio.
- ☐ Línea de tiempo.
- ☐ Acciones de respuesta.
- ☐ Validación posterior.
- ☐ INC-002 documentado.
- ☐ Conclusión técnica.

Preguntas que debe responder el informe: ¿qué pasó?, ¿cuándo?, ¿qué usuario?, ¿qué equipo?, ¿qué evento lo demuestra?, ¿qué acción tomaste?, ¿por qué?, ¿cómo comprobaste que quedó solucionado?

16. EVALUACIÓN — 100 PUNTOS

Área	Puntos
Preparación e infraestructura	15
Generación y conservación de evidencia	15
Análisis de eventos	20
Mínimo privilegio y permisos	15
Respuesta y recuperación	15
Validación de GPO	10
Documentación profesional	10
TOTAL	100

Resultado esperado: al terminar tendrás un laboratorio de dos máquinas que demuestra administración de identidades, auditoría, control de acceso, análisis de eventos, respuesta a incidentes y validación de controles. Esto representa una continuación natural de la infraestructura que ya documentaste. ■filecite■turn0file0■L221-L224■